

**America's Cyber Defense Agency**

NATIONAL COORDINATOR FOR CRITICAL INFRASTRUCTURE SECURITY AND RESILIENCE

SHARE:**BLOG**

Lessons from XZ Utils: Achieving a More Sustainable Open Source Ecosystem

Released: April 12, 2024*By: Jack Cable, Senior Technical Advisor, and Aeva Black, Section Chief, Open Source Software Security***RELATED TOPICS:** [CYBERSECURITY BEST PRACTICES](#) </topics/cybersecurity-best-practices>

A month ago at CISA, we held our first [Open Source Software Security Summit](https://www.cisa.gov/news-events/news/cisa-announces-new-efforts-help-secure-open-source-ecosystem) <https://www.cisa.gov/news-events/news/cisa-announces-new-efforts-help-secure-open-source-ecosystem>, bringing together leaders from open source foundations, package repositories, civil society, and industry. As part of this summit, we held a tabletop exercise testing coordination of community response to a hypothetical vulnerability under active exploitation in a widely used open source library. Participants noted that they gained an improved awareness of CISA's ability to assist in coordinating response efforts between private sector and OSS non-profits, as well as new insights into how their organizations could implement resilient recovery plans.

Little did we know how soon the lessons from the tabletop would be applicable. The XZ Utils compromise – a multi-year effort by a malicious threat actor to gain the trust of the package's maintainer and inject a backdoor – highlighted the fragility of key points in the

open source ecosystem, the very real and ongoing risks created by maintainer burnout, and the enormous benefits realized through open collaboration as demonstrated by the communities' response. We are fortunate that the open nature of the wider open source ecosystem allowed a developer to spot this supply chain compromise before it could cause much harm. Next time, we may not be as lucky.

This compromise highlights a fundamental shift needed: **every technology manufacturer that profits from open source software must do their part by being responsible consumers** <https://www.cisa.gov/sites/default/files/2023-12/esf_securing_the_software_supply_chain%20recommended%20practices%20for%20managing%20open%20source%20software%20and%20software%20bill%20of%20materials.pdf>

of and sustainable contributors to the open source packages they depend on. In line with our Secure by Design initiative <<https://www.cisa.gov/securebydesign>>, the burden of security shouldn't fall on an individual open source maintainer—as it did in this case to near-disastrous effect. Rather, companies consuming open source software must contribute back – either financially or through developer time – to ensure a sustainable ecosystem where open source projects have healthy and diverse maintainer communities that are resilient to burnout.

Technology manufacturers and system operators that incorporate OSS are responsible for the safety of the systems they build and operate, and should work to ensure – either directly or by supporting maintainers – that a secure by design software development approach is being followed. This includes regular code reviews, eliminating entire classes of vulnerabilities, applying security scanning tools, isolating build environments, having a documented process for responding to vulnerability reports and security incidents, and more.

At CISA, we've been working hand-in-hand with many open source communities to drive a more resilient open source ecosystem so that organizations across the world can continue to reap the countless benefits of open source software. As laid out in our open source roadmap <<https://www.cisa.gov/resources-tools/resources/cisa-open-source-software-security-roadmap>>, we're working on a number of areas, including to build relationships with open source communities, understand open source prevalence, secure the federal government's use of OSS, and help secure the broader open source ecosystem.

Specific to the XZ Utils compromise, through CISA's Joint Cyber Defense Collaborative (JCDC), we are collaborating in real-time with open source community members to better understand the impact. More broadly, we're continuing our efforts to secure open source, including [working with package repositories](https://repos.openssf.org/principles-for-package-repository-security) to scale out security improvements to entire open source ecosystems. We've also released the [package](https://www.cisa.gov/sites/default/files/2024-04/open-source-ctep-situation-manual-042024-508.docx) from our tabletop exercise that any open source community can use to practice and refine their incident response coordination abilities.

Interested in helping support CISA's open source security efforts? Drop us a note at OpenSource@cisa.dhs.gov.

OCT 02, 2024

BLOG

Region 8 Invites You to Secure Our World

</news-events/news/region-8-invites-you-secure-our-world-0>

AUG 21, 2024

BLOG

Shaping the legacy of partnership between government and private sector globally: JCDC

</news-events/news/shaping-legacy-partnership-between-government-and-private-sector-globally-jcdc>

Return to top

- Topics </topics>
- Spotlight </spotlight>
- Resources & Tools </resources-tools>
- News & Events </news-events>
- Careers </careers>
- About </about>

CISA Central

1-844-Say-CISA

SayCISA@cisa.dhs.gov

CISA.gov

An official website of the U.S. Department of Homeland Security

About CISA </about>	Budget and Performance <https://www.dhs.gov/performance-financial-reports>	DHS.gov <https://www.dhs.gov>
Equal Opportunity & Accessibility </oedia>	FOIA Requests <https://www.dhs.gov/foia>	No FEAR Act </no-fear-act>
Office of Inspector General <https://www.oig.dhs.gov/>	Privacy Policy </privacy-policy>	Subscribe
The White House <https://www.whitehouse.gov/>	USA.gov <https://www.usa.gov/>	Website Feedback </forms/feedback>